

THE JUNIOR CYBERSECURITY ENGINEER HANDBOOK

From Zero to Understanding
Defensive Security



REAL-WORLD
CONCEPTS



PRACTICAL
EXAMPLES



BEGINNER
FRIENDLY



DEFENSIVE
SECURITY FOCUS



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

UNDERSTANDING CYBERSECURITY

1. WHAT IS CYBERSECURITY?

Cybersecurity is the practice of protecting **systems, networks, applications, data, and people** from digital threats. It helps prevent unauthorized access, damage, theft, and disruption.

2. WHY DOES IT EXIST?

Because attackers try to:

- Steal sensitive information
- Disrupt services
- Gain unauthorized access
- Damage systems
- Extort money (ransomware)
- Use your systems for their own benefit



3. WHAT DO ENGINEERS PROTECT?

-  Systems (servers, cloud, endpoints)
-  Networks (on-premise and cloud)
-  Applications (web, mobile, internal)
-  Data (customer, business, financial)
-  People (users, identities, access)

4. HOW CYBERSECURITY WORKS

Engineers use people, processes and technology to reduce risk.



5. REAL-WORLD EXAMPLE

A company stores **customer data** in a cloud application. Cybersecurity helps prevent attackers from stealing that data, modifying it, or taking the application offline.

6. DEVOPS & CYBERSECURITY

DevOps engineers also play a key role in security by:

- ✓ Building secure infrastructure
- ✓ Managing access and permissions
- ✓ Keeping systems updated
- ✓ Monitoring logs and alerts
- ✓ Following secure deployment practices



7. KEY BENEFITS

- ✓ Protects sensitive information
- ✓ Keeps services available
- ✓ Builds customer trust
- ✓ Reduces financial loss
- ✓ Meets legal and regulatory requirements
- ✓ Helps businesses operate safely

8. JUNIOR ENGINEER TIP



Cybersecurity is not only the job of a security team. Every engineer, including DevOps and cloud engineers, must understand security fundamentals.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

THE CIA TRIAD EXPLAINED



Confidentiality, Integrity, and Availability are the three core principles of cybersecurity. They guide how engineers protect systems, data, and services.

1. CONFIDENTIALITY

Keeps information **private** and ensures only authorized people can access it.

- Prevents unauthorized access
- Protects sensitive data
- Uses encryption, access controls, and authentication

EXAMPLES

- Email content
- Customer database
- Financial records
- Personal information
- Company source code



2. INTEGRITY

Ensures information is **accurate, complete, and has not been changed** in an unauthorized way.

- Prevents unauthorized modification
- Detects tampering
- Uses checksums, digital signatures, and access controls

EXAMPLES

- Configuration files
- Application data
- System files
- Logs and audit records
- Software and updates

3. AVAILABILITY

Ensures systems, data, and services are **accessible and working** when needed by authorized users.

- Reduces downtime
- Prevents service disruption
- Uses redundancy, monitoring and disaster recovery

REAL-WORLD SCENARIOS



Confidentiality: Only employees can access customer data.



Integrity: A file has not been modified by an attacker.



Availability: The website is online and working for customers.

WHY THE CIA TRIAD MATTERS

- ✓ Helps organizations protect critical assets
- ✓ Guides security decisions and controls
- ✓ Used in risk management and compliance
- ✓ Applies to on-premise, cloud, and hybrid environments
- ✓ Forms the foundation of most security frameworks
- ✓ Every security engineer uses these principles every day



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

HOW CYBERATTACKS ACTUALLY HAPPEN



A beginner-friendly attack sequence, from initial access to potential compromise and impact.

1. WHAT IS A CYBERATTACK?

A cyberattack is a deliberate attempt to **gain unauthorized access, steal data, disrupt services, modify systems, or take control** of a digital environment.

2. ATTACKER GOAL

Attackers may want to:

- Steal sensitive information
- Gain long-term access
- Disrupt operations
- Make financial gain
- Use the environment for further attacks



3. THE COMMON ATTACK SEQUENCE

1. RECONNAISSANCE



Attacker gathers information about the target.

Examples:

- Find exposed services
- Search company info
- Identify employee emails

2. INITIAL ACCESS



Attacker gains a foothold in the environment.

Examples:

- Phishing email
- Exploiting a vulnerability
- Weak password
- Malicious file

3. ESTABLISH ACCESS



Attacker maintains access for future use.

Examples:

- Create backdoor
- Add a new user
- Install malware
- Use valid credentials

4. MOVE Laterally



Attacker moves to other systems and gains more access.

Examples:

- Access internal servers
- Steal more credentials
- Use administrator accounts

5. ACHIEVE OBJECTIVE



Attacker reaches their main goal.

Examples:

- Steal data
- Encrypt systems (ransomware)
- Disrupt services
- Use for further attacks

4. REAL-WORLD EXAMPLE (PHISHING ATTACK)

- You receive a fake email that looks real.
- You click a malicious link.
- Malware is installed on your device.
- Attacker steals your credentials.
- Attacker accesses internal systems.
- Sensitive data is stolen or systems are encrypted.

5. COMMON ATTACK METHODS

- Phishing (fake emails)
- Malware (malicious software)
- Brute-force attacks (guessing passwords)
- Exploiting vulnerabilities (unpatched systems)
- Social engineering (tricking people)
- Web application attacks (SQL injection, etc.)
- Network attacks (sniffing, man-in-the-middle)

6. IMPACT OF A SUCCESSFUL ATTACK

- Data theft
- System modification
- Service disruption
- Financial loss
- Reputational damage
- Legal and regulatory issues

7. KEY TAKEAWAY



Cyberattacks usually happen in stages. Understanding these stages helps you detect, prevent, and respond to attacks.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

UNDERSTANDING THE ATTACK SURFACE



The attack surface is the total number of exposed services, accounts, applications, devices, and cloud resources that attackers can find and potentially exploit.

1. WHAT IS THE ATTACK SURFACE?

The attack surface is everything that is **accessible** from the internet or from within a network that an attacker can **discover, interact with, or exploit**.

2. WHY IT MATTERS?

- Attackers look for exposed and vulnerable assets.
- A larger attack surface increases the chance of a successful attack.
- Reducing the attack surface lowers risk.
- It helps protect data, systems, and business operations.



3. COMMON PARTS OF AN ATTACK SURFACE

A. SERVICES AND PORTS



- Exposed services (e.g. SSH, RDP, web servers, databases)
- Open ports
- Unnecessary services
- Misconfigured applications

B. ACCOUNTS AND IDENTITIES



- User accounts
- Admin accounts
- Weak passwords
- Unused accounts
- Overly permissive access

C. APPLICATIONS



- Web applications
- APIs
- Unpatched software
- Misconfigured applications
- Vulnerable dependencies

D. DEVICES AND ENDPOINTS



- Laptops and desktops
- Mobile devices
- IoT devices
- Printers and network devices
- Unmanaged or lost devices

E. NETWORK INFRASTRUCTURE



- Routers and firewalls
- Network devices
- VPN access
- Exposed management interfaces
- Misconfigured network rules

F. CLOUD RESOURCES



- Cloud storage (e.g. S3)
- Virtual machines
- Databases
- Serverless functions
- Misconfigured permissions
- Publicly exposed resources



4. REAL-WORLD EXAMPLE



A company exposes a web application with a vulnerable plugin, has unused admin accounts, and leaves a cloud storage bucket open. An attacker finds one of these, gains access, and moves deeper into the network.

5. COMMON MISTAKES

- ✗ Leaving unnecessary services open
- ✗ Using weak or default passwords
- ✗ Not patching systems
- ✗ Over-permissioned accounts
- ✗ Exposing cloud resources publicly
- ✗ Forgetting old or unused accounts
- ✗ Not monitoring the attack surface

6. HOW TO REDUCE IT

- ✓ Close unnecessary ports and services
- ✓ Use strong access controls
- ✓ Apply regular patches
- ✓ Remove unused accounts
- ✓ Secure cloud configurations
- ✓ Use network segmentation
- ✓ Regularly scan and review exposed assets



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

THREATS, VULNERABILITIES AND RISK

Understanding the difference between a threat, a weakness, an exploit, and the resulting security risk.

1. THREAT

A threat is anything that can **cause harm** to your systems, data, or services.



Examples:

- Hackers
- Malware
- Insiders
- Natural disasters
- Human error

2. VULNERABILITY

A vulnerability is a **weakness** in a system, application, process, or configuration that can be exploited.



Examples:

- Unpatched software
- Weak passwords
- Misconfigured servers
- Open ports
- Missing security controls

3. EXPLOIT

An exploit is a method or tool used by an attacker to **take advantage** of a vulnerability.



Examples:

- Malicious code
- Exploit scripts
- Social engineering
- Brute-force tools
- Zero-day exploits

4. RISK

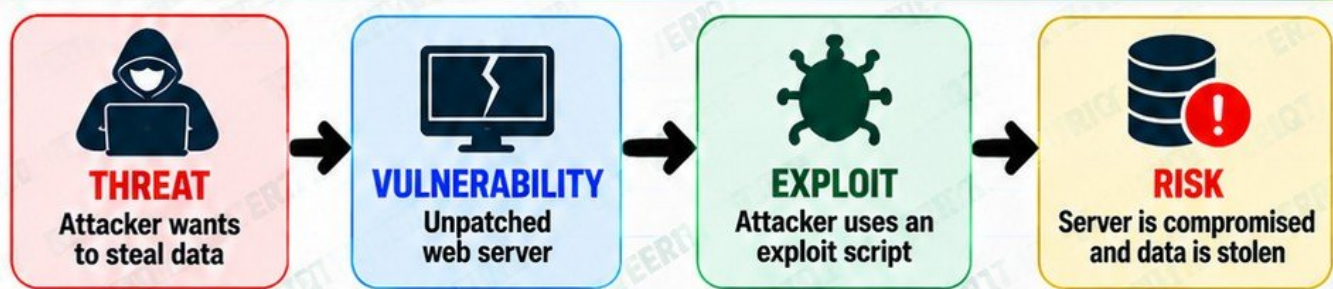
Risk is the **potential impact** when a threat successfully exploits a vulnerability.



Examples:

- Data breach
- Financial loss
- Service downtime
- Reputational damage
- Legal and regulatory penalties

5. HOW THEY CONNECT



6. REAL-WORLD EXAMPLE

A company has a web server with an **unpatched vulnerability** (threat: hackers). An attacker uses an **exploit** to gain access and **steals customer data** (resulting **risk**: data breach, financial loss, and legal issues).



7. KEY TAKEAWAYS

- ✓ Threats are the potential danger.
- ✓ Vulnerabilities are the weaknesses.
- ✓ Exploits are the methods used to take advantage.
- ✓ Risk is the potential impact.
- ✓ Reducing vulnerabilities lowers risk.
- ✓ Security controls help prevent exploitation.

8. HOW TO REDUCE RISK

-  Keep systems updated
-  Use strong access controls
-  Remove unnecessary services
-  Regular security assessments
-  Monitor and detect threats
-  Have an incident response plan



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

AUTHENTICATION VS AUTHORIZATION



How systems verify identities, control access, and enforce least privilege.

1. WHAT IS AUTHENTICATION?

Authentication **verifies who you are**. It confirms your identity using something you know, have, or are.

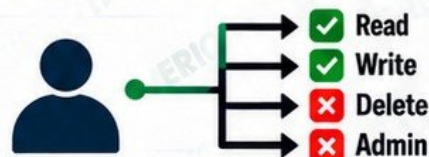


Common authentication methods:

- Username and password
- Multi-factor authentication (MFA)
- SSH key pair
- Biometric authentication (fingerprint, face)
- Security tokens (e.g. OTP, smart card)

2. WHAT IS AUTHORIZATION?

Authorization determines **what you can do** after you have been authenticated.



Common authorization methods:

- Role-based access control (RBAC)
- Attribute-based access control (ABAC)
- Access Control Lists (ACLs)
- Policies and permissions
- Group membership

3. KEY DIFFERENCES

FEATURE	AUTHENTICATION	AUTHORIZATION
Purpose	Verifies your identity	Determines your access
Answers	Who are you?	What can you do?
When it happens	First	After authentication
Example	Login with password or MFA	Allow read, write or admin access
Failure result	Access denied (cannot log in)	Limited or no access to resources

4. HOW THEY WORK TOGETHER



You must be authenticated before you can be authorized. Even a valid user can only access what they are allowed to.

5. REAL-WORLD EXAMPLES



You log in to your email with a password (authentication). You can only read your own emails (authorization).



You log in to AWS with MFA (authentication). Your IAM role allows you to start EC2 instances but not delete them (authorization).



You connect to a Linux server using an SSH key (authentication). Your user has read-only access to a directory (authorization).



You log in to a company application (authentication). Your role gives you access to specific features (authorization).

6. LEAST PRIVILEGE PRINCIPLE



Give users only the **minimum access** they need to do their job.

- Reduces risk if an account is compromised
- Limits damage from accidental changes
- Prevents unauthorized access
- Helps meet compliance requirements

7. COMMON MISTAKES

- ✗ Using weak passwords
- ✗ Not enabling MFA
- ✗ Giving users more permissions than needed
- ✗ Using shared accounts
- ✗ Not reviewing and removing unused access



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

UNDERSTANDING COMMON CYBERATTACKS



Phishing, malware, ransomware, brute-force attacks, credential theft, and denial-of-service attacks.

1. PHISHING ATTACKS

Phishing tricks people into giving up sensitive information by pretending to be a trusted source.



Examples:

- Fake emails
- Fake login pages
- Messages from imposters
- Malicious links or attachments

2. MALWARE

Malware is malicious software designed to damage systems, steal data, or gain unauthorized access.



Types:

- Viruses
- Trojans
- Worms
- Spyware
- Keyloggers

3. RANSOMWARE

Ransomware encrypts your files or systems and demands payment to restore access.

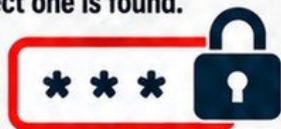


Typical impact:

- Files become inaccessible
- Business operations stop
- Data may be leaked
- Financial loss and reputation damage

4. BRUTE-FORCE ATTACKS

A brute-force attack tries many password combinations until the correct one is found.



Common targets:

- User accounts (SSH, RDP, VPN)
- Web application logins
- Email accounts
- Admin accounts

5. CREDENTIAL THEFT

Attackers steal usernames, passwords, or other credentials to gain unauthorized access.



Methods:

- Phishing
- Malware (keyloggers)
- Data breaches
- Social engineering
- Password cracking

6. DENIAL-OF-SERVICE (DoS/DDoS)

A DoS or DDoS attack overwhelms a system with traffic, making it unavailable to legitimate users.



Impact:

- Website or service becomes slow or unavailable
- Loss of business and revenue
- Can be used as a distraction for other attacks

7. COMPARISON OVERVIEW

Attack Type	Main Goal	Common Method	Main Impact
Phishing	Steal information	Fake emails/links	Credential theft
Malware	Damage or gain access	Malicious software	Data theft, system compromise
Ransomware	Extort money	Encrypt files	Operational and financial loss
Brute-force	Gain access	Try many passwords	Account takeover
Credential theft	Steal credentials	Phishing, malware	Unauthorized access
DoS/DDoS	Disrupt services	Flood with traffic	Service downtime

8. KEY TAKEAWAYS

- ✓ Attackers use different methods for different goals.
- ✓ Many attacks start with human mistakes.
- ✓ Strong passwords and MFA reduce the risk.
- ✓ Keep systems updated and patched.
- ✓ Be careful with emails, links, and attachments.
- ✓ Monitor for unusual activity.
- ✓ Use security controls like firewalls, detection systems, and access controls.
- ✓ A combination of people, process, and technology helps prevent attacks.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

NETWORK SECURITY FUNDAMENTALS



IP addresses, ports, protocols, firewalls, segmentation, and how network traffic is controlled.

1. WHAT IS A NETWORK?

A network **connects** devices so they can **communicate** and share resources, data, and services using defined rules (protocols).



2. IP ADDRESSES

An IP address is a **unique** address that identifies a device on a network.

IPv4 (e.g. 192.168.1.10)

- 32-bit address
- Most common



IPv6 (e.g. 2001:db8::1)

- 128-bit address
- More addresses for modern networks



3. PORTS

Ports are logical entry points on a device used by applications and services.

Port	Service	Protocol
22	SSH	TCP
80	HTTP	TCP
443	HTTPS	TCP
3389	RDP	TCP
53	DNS	UDP/TCP
110	POP3	TCP
25	SMTP	TCP

4. PROTOCOLS

Protocols are **rules** that define how data is formatted, sent, and received.

- HTTP / HTTPS (web traffic)
- TCP / UDP (transport layer)
- DNS (name resolution)
- SSH (secure access)
- FTP / SFTP (file transfer)
- SMTP (email)
- ICMP (network testing)

5. HOW NETWORK TRAFFIC WORKS

When you access a website, your device sends a request (packet) to a server, and the server responds with data.



- Your device creates a packet (source IP, destination IP, port, protocol).
- The packet travels through routers and networks.
- The server receives the packet and sends a response.
- Your device receives the response and displays the content.

6. FIREWALLS

A firewall controls network traffic by allowing or blocking connections based on security rules.



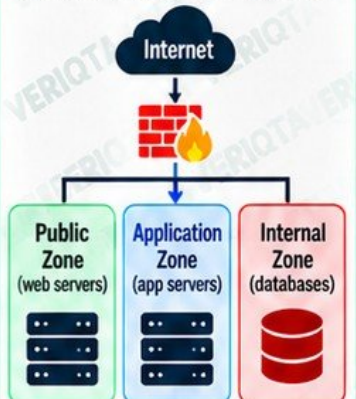
- Allow trusted traffic
- Block suspicious or unauthorized traffic

Types of firewalls:

- Network firewall (hardware or software)
- Host-based firewall (on a device)
- Cloud firewall (e.g. AWS Security Groups)
- Next-generation firewall (NGFW)

7. NETWORK SEGMENTATION

Segmentation divides a network into smaller, isolated parts to reduce risk and control access.



8. COMMON NETWORK DEVICES



Router

Connects different networks



Switch

Connects devices within a network



Firewall

Controls traffic based on rules



Access Point

Provides wireless access



Load Balancer

Distributes traffic across multiple servers

9. TRAFFIC CONTROL METHODS

- Firewall rules (allow/deny)
- Access control lists (ACLs)
- Network segmentation
- Intrusion detection and prevention systems (IDS/IPS)
- Rate limiting (prevent abuse)
- VPNs (secure remote access)
- Monitoring and logging
- Using secure protocols (e.g. HTTPS, SSH)
- Keeping services and ports to a minimum
- Regular security reviews

10. KEY TAKEAWAYS



- IP addresses identify devices.
- Ports allow applications to communicate.
- Protocols define how data is sent and received.
- Firewalls control traffic.
- Segmentation reduces risk.
- Traffic should be monitored, restricted, and secured.
- Only necessary services and ports should be open.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

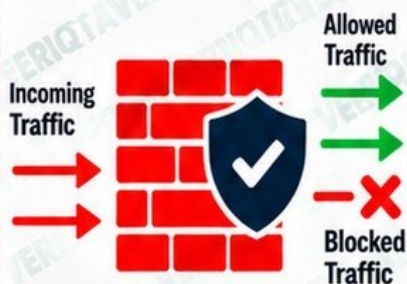
HOW FIREWALLS PROTECT SYSTEMS



Inbound and outbound rules, permitted traffic, blocked connections, and common configuration mistakes.

1. WHAT IS A FIREWALL?

A firewall is a security control that **monitors and filters** network traffic based on defined rules. It **allows** permitted traffic and **blocks** unwanted or suspicious traffic.



2. HOW A FIREWALL WORKS

- 1 Traffic arrives at the firewall (from Internet or internal network).
- 2 The firewall checks the traffic against its security rules.
- 3 If the traffic matches an **allow rule**, it is permitted.
- 4 If the traffic matches a **deny rule**, it is blocked.
- 5 The firewall logs the activity for monitoring and investigation.



3. INBOUND VS OUTBOUND RULES

Inbound Rules (control traffic coming in)



- ✓ Allow specific services (e.g. HTTPS, SSH)
- ✓ Block unwanted traffic
- ✓ Reduce exposure to the internet

Outbound Rules (control traffic going out)



- ✓ Allow necessary traffic (e.g. updates, DNS, API)
- ✓ Block suspicious or unauthorized traffic
- ✓ Prevent data exfiltration

4. COMMON FIREWALL TYPES

	Network Firewall	Filters traffic between networks (e.g. on-premises or cloud).
	Host-based Firewall	Runs on individual devices (e.g. Windows Firewall, Linux firewalld).
	Cloud Firewall	Protects cloud resources (e.g. AWS Security Groups, Azure Firewall).
	Next-Generation Firewall (NGFW)	Includes advanced features like IDS/IPS, application filtering, and threat detection.

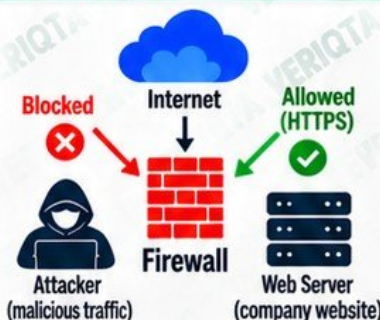
5. EXAMPLE FIREWALL RULES

Direction	Source	Destination	Port	Action	Description
Inbound	Any	Web Server	80	Allow	Allow HTTP traffic
Inbound	Any	Web Server	443	Allow	Allow HTTPS traffic
Inbound	Any	Web Server	22	Deny	Block direct SSH access
Outbound	Web Server	Internet	53	Allow	Allow DNS queries
Outbound	Web Server	Internet	443	Allow	Allow software updates
Outbound	Web Server	Any	25	Deny	Block unauthorized email

6. COMMON CONFIGURATION MISTAKES

- ✗ Allowing unnecessary open ports.
- ✗ Using overly broad rules (e.g. allowing any source).
- ✗ Not blocking unused services.
- ✗ Allowing outbound traffic without restriction.
- ✗ Forgetting to update firewall rules after changes.
- ✗ Not logging or monitoring firewall activity.
- ✗ Relying only on a firewall without other security controls.

7. REAL-WORLD EXAMPLE



8. KEY TAKEAWAYS

- ✓ Firewalls control inbound and outbound traffic.
- ✓ Only allow necessary services and ports.
- ✓ Block unwanted and suspicious connections.
- ✓ Use specific and well-defined rules.
- ✓ Regularly review and update rules.
- ✓ Monitor logs for unusual activity.
- ✓ Combine firewalls with other security controls (IDS/IPS, monitoring).



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

LINUX SECURITY FUNDAMENTALS



Users, groups, file permissions, sudo, SSH protection, and basic system hardening.

1. USERS AND GROUPS

Users and groups control who can log in and what they can access.



Common commands:

```
# create a user
sudo useradd devuser

# set a password
sudo passwd devuser

# create a group
sudo groupadd devops

# add user to group
sudo usermod -aG devops devuser

# view users and groups
id devuser
getent group devops
```

2. FILE PERMISSIONS

File permissions control who can read, write, or execute files and directories.

Owner	Group	Others
r w x	r w x	r w x
7	5	0

Common commands:

```
# view permissions
ls -l

# change permissions (numeric)
chmod 750 file.txt

# change permissions (symbolic)
chmod u+rw,g+rx,o-rwx file.txt

# change owner and group
sudo chown user:group file.txt
```

3. SUDO (PRIVILEGE ESCALATION)

Sudo allows authorized users to run commands with administrative privileges.



Common commands:

```
# run a command with sudo
sudo apt update

# edit sudo configuration
sudo visudo

# example: allow a user to run specific commands
devuser ALL=(ALL) /usr/bin/systemctl
```

4. SSH PROTECTION

Secure SSH to prevent unauthorized access.



Key steps:

- ✓ Use key-based authentication (instead of passwords)
- ✓ Disable direct root login
- ✓ Change the default port (optional)
- ✓ Allow only specific users or IPs
- ✓ Use strong keys (e.g. ed25519)

Important configuration (/etc/ssh/sshd_config):

```
Port 2222
PermitRootLogin no
PasswordAuthentication no
AllowUsers devuser
```

Restart SSH:

```
sudo systemctl restart sshd
```

5. BASIC SYSTEM HARDENING

Reduce the attack surface and make your system more secure.

- ✓ Keep the system updated
- ✓ Remove unnecessary packages
- ✓ Disable unused services
- ✓ Configure a firewall
- ✓ Use strong passwords or SSH keys
- ✓ Monitor logs for suspicious activity
- ✓ Limit access to sensitive files
- ✓ Use file permission best practices
- ✓ Enable automatic security updates

Useful commands:

```
# update the system
sudo apt update && sudo apt upgrade

# check running services
systemctl list-units --type=service

# disable a service
sudo systemctl disable servicename

# enable firewall (UFW)
sudo ufw enable

# check system logs
sudo journalctl -xe
```

6. COMMON FILE PERMISSIONS EXAMPLES

Permission	Meaning	Example	Use Case
755	rwX r-X r-X	drwxr-xr-x	Directory (owner full, others read/execute)
644	rw- r-- r--	-rw-r--r--	File (owner read/write, others read)
600	rw- --- ---	-rw-----	File (owner only)
700	rwX --- ---	drwx-----	Directory (owner only)
750	rwX r-X ---	drwxr-x---	Directory (owner and group only)

7. REAL-WORLD EXAMPLE

Secure a new Linux server:

- 1 Create a non-root user.
- 2 Add user to sudo group.
- 3 Set up SSH key authentication.
- 4 Disable root login and password auth.
- 5 Configure a firewall.
- 6 Keep system updated.
- 7 Verify file permissions on sensitive files.

8. KEY TAKEAWAYS

- ✓ Use least privilege.
- ✓ Manage users and groups properly.
- ✓ Set correct file permissions.
- ✓ Restrict and secure SSH access.
- ✓ Keep your system updated.
- ✓ Disable unnecessary services.
- ✓ Use a firewall.
- ✓ Monitor logs.
- ✓ Follow security best practices to reduce risk.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

UNDERSTANDING SECURITY LOGS



What security logs record, where engineers find them, and how logs help identify suspicious activity.

1. WHAT ARE SECURITY LOGS?

Security logs are records of events that happen on systems, applications, and network devices. They capture important information that helps engineers detect, investigate, and respond to suspicious activity.



Logs help you:

- See what happened
- Identify suspicious activity
- Investigate security incidents
- Meet compliance requirements

2. WHAT DO LOGS RECORD?

Logs capture a wide range of events, including:

- User logins and logouts
- Successful and failed authentication attempts
- File and directory access
- Privilege escalation (sudo)
- Changes to system configuration
- Application errors and security events
- Network connections (source, destination, ports)
- Firewall allow/deny events
- Malware detections
- System startup and shutdown
- Service and process activity
- Account creation, deletion, and changes



3. WHERE TO FIND LOGS?

Logs are stored in different locations depending on the system and tool.

Source / System	Common Log Location
Linux (system logs)	/var/log/
Authentication logs	/var/log/auth.log (Ubuntu/Debian)
Secure log (RHEL/CentOS)	/var/log/secure
Systemd logs	journalctl
Web server (Apache)	/var/log/apache2/
Web server (Nginx)	/var/log/nginx/
Firewall (UFW)	/var/log/uwfw.log
Application logs	/var/log/<app>/
Cloud (AWS)	CloudWatch Logs
Windows (Event Logs)	Event Viewer
Network devices	Syslog server
Security tools (e.g. IDS)	/var/log/snort/

4. REAL-WORLD LOG EXAMPLES

Successful login

```
Oct 10 09:15:22 server sshd[1234]:
Accepted publickey for user john
from 192.168.1.10 port 54322 ssh2
```

Failed login attempt

```
Oct 10 09:16:05 server sshd[1235]:
Failed password for invalid user admin
from 203.0.113.25 port 45112 ssh2
```

Sudo usage

```
Oct 10 09:20:11 server sudo: john : TTY=pts/0 ;
USER=root ; COMMAND=/bin/systemctl restart nginx
```

File access

```
Oct 10 09:25:44 server audit[2345]:
SYSCALL arch=c000003e syscall=2 success=yes
exe="/usr/bin/cat" name="/etc/passwd"
```

Firewall blocked connection

```
Oct 10 09:28:17 server UFW BLOCK:
IN=eth0 OUT= MAC=C... SRC=203.0.113.25
DST=192.168.1.10 LEN=60 TOS=0x00 PREC=0x00
PROTO=TCP SPT=34567 DPT=22
```

5. USEFUL COMMANDS (LINUX)

View and filter logs using common commands.

Task	Command
View system logs	journalctl -xe
View auth logs	sudo cat /var/log/auth.log
View secure logs (RHEL/CentOS)	sudo cat /var/log/secure
View last logins	last
View failed logins	grep "Failed password" /var/log/auth.log
Search for a specific user	grep "username" /var/log/auth.log
View real-time logs	sudo tail -f /var/log/syslog
View firewall logs	sudo cat /var/log/uwfw.log
Filter by IP address	grep "192.168.1.10" /var/log/auth.log
Count failed logins	grep "Failed password" /var/log/auth.log wc -l

7. COMMON SUSPICIOUS INDICATORS

- ⚠ Multiple failed login attempts from the same IP.
- ⚠ Logins from unusual locations or at odd times.
- ⚠ Use of disabled or unknown accounts.
- ⚠ Access to sensitive files (e.g. /etc/passwd).
- ⚠ Unexpected changes to system configuration.
- ⚠ Suspicious processes or services running.
- ⚠ Unusual outbound network connections.

6. HOW LOGS HELP DETECT ATTACKS



Identify failed login attempts (brute-force).



Detect malware activity.



Track suspicious file access.



See unusual network connections.



Monitor changes to system configuration.



Detect privilege escalation and unauthorized access.

8. KEY TAKEAWAYS

- ✓ Security logs record important events on systems and applications.
- ✓ Engineers use logs to detect, investigate, and respond to security incidents.
- ✓ Logs are stored in different locations depending on the system.
- ✓ Regular log monitoring helps identify suspicious activity early.
- ✓ Combine logs with other security tools for better detection and response.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

INTRODUCTION TO THE SOC



What a Security Operations Center does and how analysts monitor, investigate, and escalate security events.

1. WHAT IS A SOC?

A Security Operations Center (SOC) is a team, set of people, tools, and processes that continuously monitor, detect, investigate, and respond to security threats across an organization.



Main goals:

- Detect and stop attacks
- Reduce risk and impact
- Investigate suspicious activity
- Respond to incidents
- Keep the organization secure 24/7

2. KEY SOC FUNCTIONS



MONITOR

Continuously watch logs, alerts, and network activity.



DETECT

Identify suspicious or malicious activity.



INVESTIGATE

Analyze alerts and gather evidence to understand what happened.



RESPOND

Take action to contain and remove threats.



ESCALATE

Escalate serious incidents to higher teams (e.g. IR, IT, management).



IMPROVE

Learn from incidents and improve detection and response.

3. SOC ANALYST ROLES



L1 ANALYST (TIER 1)

- Monitor alerts
- Perform initial triage
- Identify false positives
- Escalate real threats



L2 ANALYST (TIER 2)

- Deep investigation
- Threat hunting support
- Analyze logs and artifacts
- Contain threats
- Escalate complex cases



L3 ANALYST (TIER 3)

- Advanced threat analysis
- Malware analysis
- Incident response support
- Develop detection rules
- Hunt for sophisticated threats



SOC MANAGER

- Oversee SOC operations
- Manage processes and tools
- Coordinate with other teams
- Report on security posture
- Drive continuous improvement

4. HOW A SOC WORKS

The SOC collects data from many sources, analyzes it using security tools, and follows a process to detect and respond to threats.



5. COMMON TOOLS IN A SOC

	SIEM	Collects and analyzes logs (e.g. Splunk, Microsoft Sentinel).
	EDR	Monitors and detects threats on endpoints (e.g. CrowdStrike).
	IDS/IPS	Detects and blocks malicious network traffic (e.g. Suricata).
	Firewall	Controls network traffic (e.g. Fortinet, Palo Alto).
	Threat Intel	Provides information about known threats (e.g. MISP).
	SOAR	Helps automate response actions (e.g. Cortex XSOAR).
	Log Management	Stores and searches logs (e.g. ELK Stack).

6. ALERT INVESTIGATION FLOW

- Alert is generated**
From a log, security tool, or rule.
- Triage the alert**
Check severity, source, and context.
- Investigate**
Review logs, timelines, and artifacts.
- Determine outcome**
False positive, true threat, or unknown.
- Take action**
Close, contain, or escalate.
- Document**
Record findings and lessons learned.

7. EXAMPLE SOC ALERT

Apr 10 14:23:11 server01 sshd[1234]: Failed password for invalid user admin from 203.0.113.25 port 52418 ssh2

Field	Meaning
Apr 10 14:23:11	Date and time of the event
sshd[1234]	SSH service generated the log (PID 1234)
Failed password	Failed login attempt
invalid user admin	Attacker tried to login as user "admin" (does not exist)
203.0.113.25	Source IP address (attacker)
port 52418	Source port used by the attacker
ssh2	SSH protocol version

8. KEY TAKEAWAYS

- ✓ A SOC monitors, detects, investigates, and responds to security threats.
- ✓ Analysts use logs, alerts, and tools to identify suspicious activity.
- ✓ SOC analysts work in different tiers (L1, L2, L3) with different responsibilities.
- ✓ Common tools include SIEM, EDR, IDS/IPS, firewalls, and threat intelligence.
- ✓ Investigations follow a structured process from alert to resolution.
- ✓ Proper logging, monitoring, and response help reduce the impact of attacks.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

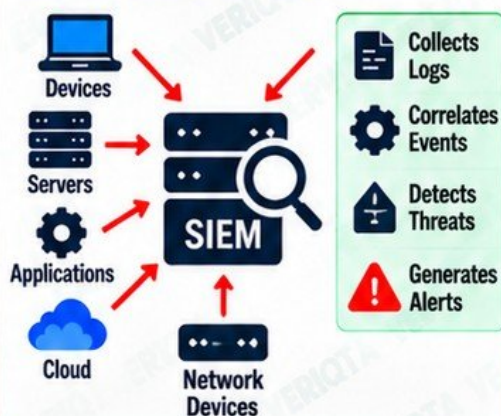
SIEM EXPLAINED FOR BEGINNERS



How Security Information and Event Management systems collect, correlate, search, and alert on security data.

1. WHAT IS A SIEM?

A SIEM (Security Information and Event Management) collects logs and security data from different sources, correlates the data to find suspicious activity, and alerts analysts so they can investigate and respond to security incidents.



2. HOW A SIEM WORKS

- 1 Collects data**
Ingests logs and events from multiple sources (servers, network devices, cloud, apps).
 - 2 Normalizes data**
Converts different log formats into a common format.
 - 3 Correlates events**
Uses rules and analytics to identify suspicious patterns.
 - 4 Generates alerts**
Triggers alerts when a potential threat is detected.
 - 5 Provides visibility**
Gives analysts a central view of security events across the environment.
- Logs → Correlation → Alert → Investigation

3. COMMON SIEM DATA SOURCES

- Operating systems (Windows, Linux)
- Firewalls and network devices (e.g. Cisco, Fortinet, Palo Alto)
- Security tools (IDS/IPS, EDR, Antivirus)
- Cloud platforms (AWS, Azure, GCP)
- Applications (Web servers, databases, IAM)
- Identity and access systems (Active Directory, Okta, etc.)
- Network logs (VPN, DNS, DHCP, NetFlow)
- Others (NAS, email security, SaaS tools)

4. SIEM EXAMPLE FLOW



5. EXAMPLE SIEM ALERT

Time: Oct 10 14:23:11
 Source: 192.168.1.10
 Event: Multiple failed SSH logins
 Rule: Brute force detection
 Severity: High
 Action: Alert generated for investigation



6. POPULAR SIEM TOOLS



7. KEY SIEM FEATURES

- Collects and centralizes logs
- Real-time and historical search
- Correlation rules and alerting
- Dashboards and reporting
- Threat detection and analytics
- Compliance and audit support
- Integration with many data sources
- Scalability for large environments
- Helps with incident investigation and response

8. KEY TAKEAWAYS

- A SIEM collects, correlates, and analyzes security data from different sources.
- It helps detect suspicious activity early.
- Engineers and analysts use SIEM for monitoring, investigation, and incident response.
- Common tools include Splunk, Microsoft Sentinel, IBM QRadar, Elastic, and more.
- SIEM is an essential tool in modern SOC environments.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

SECURITY ALERTS VS INCIDENTS



Understand events, detections, alerts, false positives, and confirmed security incidents.

1. KEY TERMS



EVENT

Any activity that happens in a system, application, or network. Events are recorded in logs.



DETECTION

A rule or analytics logic that identifies a suspicious pattern in events.



ALERT

A notification generated when a detection is triggered.



FALSE POSITIVE

An alert that looks suspicious but is actually a normal and safe activity.



INCIDENT

A confirmed security event that represents a real threat or breach and requires response.

2. HOW THEY ARE RELATED



EVENT

A user logs in from an unusual location.



DETECTION

A SIEM rule detects multiple failed login attempts.



ALERT

An alert is generated and sent to the SOC.



INVESTIGATION

The analyst reviews the alert to determine if it is real or a false positive.



FALSE POSITIVE

No real threat. Close the alert and document the reason.



CONFIRMED INCIDENT

Real security threat. Follow incident response process.

3. EXAMPLE SCENARIO



1. EVENT

Multiple failed SSH login attempts from an unknown IP address.



2. DETECTION

SIEM rule detects brute-force pattern.



3. ALERT

Alert is generated in the SIEM and sent to the SOC.



4. INVESTIGATION

Analyst checks logs, user history, and threat intelligence.



5. FALSE POSITIVE (example)

The IP belongs to a trusted security scanner. No threat.



6. CONFIRMED INCIDENT (example)

The login attempts are from a known malicious IP. Incident is created and escalated.

4. ALERT VS INCIDENT COMPARISON

Aspect	Alert	Incident
What it is	Notification from a detection rule	Confirmed security threat
Source	Generated by SIEM, EDR, IDS/IPS, or security tools	Validated through investigation
Volume	High (many per day)	Low (only real threats)
Accuracy	Can be true or false (may be a false positive)	Confirmed as real
Action	Investigate and determine if it is a real threat	Follow incident response process (contain, eradicate, recover)
Example	Multiple failed logins, unusual process, suspicious file download	Confirmed malware infection, data exfiltration, unauthorized access

5. COMMON ALERT TYPES

- Multiple failed login attempts
- Suspicious file downloads
- Privilege escalation attempts
- Suspicious process execution
- Unusual network connections
- Malware detection
- Policy violations (e.g. disabled AV)
- Unusual data access or exfiltration
- Changes to critical system files
- Suspicious email activity

6. KEY TAKEAWAYS

- Events are normal activities recorded in logs.
- Detections use rules and analytics to find suspicious patterns.
- Alerts are generated when a detection is triggered.
- Not every alert is a real threat (false positives are common).
- Incidents are confirmed security threats that require response.
- Analysts investigate alerts to determine if they are real or false.
- A good SOC process reduces false positives and focuses on real incidents.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

INTRODUCTION TO THREAT DETECTION



How defenders identify suspicious behavior using indicators, detection rules, and system telemetry.

1. WHAT IS THREAT DETECTION?

Threat detection is the process of identifying suspicious or malicious activity in systems, networks, and applications before it causes significant damage.



It helps defenders:

- ✓ Find threats early
- ✓ Understand attacker behavior
- ✓ Reduce risk and impact
- ✓ Enable faster response

2. KEY DETECTION INPUTS



INDICATORS OF COMPROMISE (IOCs)

Known malicious artifacts such as IP addresses, domains, file hashes and URLs.



DETECTION RULES

Logic that looks for suspicious patterns in logs and telemetry.



SYSTEM TELEMETRY

Data collected from endpoints, servers, network devices, cloud environments and applications.



THREAT INTELLIGENCE

Information about latest threats, attacker tactics, and campaigns.



BEHAVIOR ANALYSIS

Identifying unusual or abnormal activity compared to normal behavior.



CONTEXT

User, device, time, location and environment details to reduce false positives.

3. HOW THREAT DETECTION WORKS



COLLECT DATA

Gather logs, telemetry and events from multiple sources (endpoints, network, cloud, apps).



APPLY DETECTION LOGIC

Use rules, analytics and threat intelligence to find suspicious patterns.



GENERATE ALERTS

Create alerts when potential threats are detected.



INVESTIGATE

Analysts review the alert, check context and determine if it is real or a false positive.



RESPOND

If confirmed, take action to contain, remediate and prevent further attacks.

4. EXAMPLES OF SUSPICIOUS BEHAVIOR



Multiple failed login attempts



Suspicious commands (e.g. PowerShell, bash)



Access to sensitive files (e.g. /etc/passwd, customer data)



Unusual network connections (to unknown IPs)



Unexpected data uploads or data exfiltration



Suspicious process creation or persistence

5. DETECTION RULE EXAMPLE

Rule: Multiple Failed SSH Logins

IF more than 5 failed SSH logins from the same IP within 10 minutes
THEN generate an alert

This could indicate:

- ✓ Brute-force attack
- ✓ Credential stuffing
- ✓ Compromised account
- ✓ Automated scanning activity

6. REAL-WORLD LOG EXAMPLE

```
Oct 10 09:15:10 server1 sshd[1234]:
Failed password for invalid user
admin from 203.0.113.25 port 54321
ssh2

Oct 10 09:15:22 server1 sshd[1234]:
Failed password for invalid user
admin from 203.0.113.25 port 54322
ssh2

Oct 10 09:15:35 server1 sshd[1234]:
Failed password for invalid user
admin from 203.0.113.25 port 54323
ssh2
```

7. COMMON DETECTION SOURCES



Operating system logs (Windows/Linux)



Firewall logs



Network device logs (router, switch)



Cloud logs (AWS, Azure, GCP)



Application logs (web, database)



Security tools (EDR, IDS/IPS, SIEM)

8. KEY TAKEAWAYS

- ✓ Threat detection uses indicators, rules and telemetry to find suspicious activity.
- ✓ It helps identify threats early and reduce impact.
- ✓ Context and analysis are important to avoid false positives.
- ✓ Detection sources include endpoints, network, cloud and apps.
- ✓ Analysts investigate alerts to confirm if they are real.
- ✓ Effective threat detection improves security and response time.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

VULNERABILITY MANAGEMENT BASICS



Discovering weaknesses, evaluating severity and exposure, prioritizing remediation, and verifying fixes.

1. WHAT IS VULNERABILITY MANAGEMENT?

Vulnerability management is the continuous process of finding, assessing, prioritizing, remediating, and verifying security weaknesses in systems, applications, and infrastructure to reduce risk.



It helps organizations:

- ✓ Find and fix security weaknesses early
- ✓ Reduce the attack surface
- ✓ Prevent security incidents
- ✓ Meet compliance and security requirements
- ✓ Keep systems and data safe

2. THE VULNERABILITY MANAGEMENT PROCESS



1. DISCOVER

Find vulnerabilities in systems, applications, and infrastructure using scanners and other methods.



2. ASSESS

Evaluate severity, exploitability, exposure, and business impact.



3. PRIORITIZE

Focus on the vulnerabilities that pose the highest risk.



4. REMEDIATE

Apply patches, configuration changes, or other fixes.



5. VERIFY

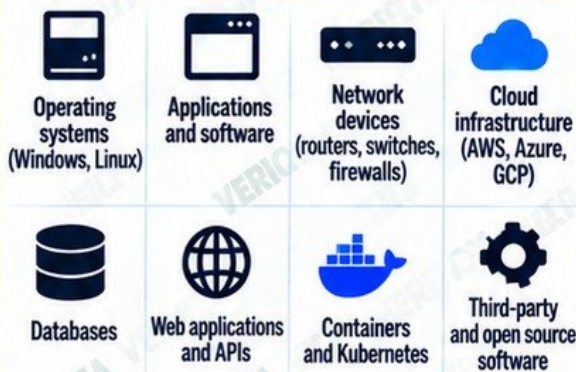
Confirm the vulnerability is fixed and no longer exploitable.

3. SEVERITY AND RISK RATING

Vulnerabilities are rated based on severity to help with prioritization. The most common standard is CVSS (Common Vulnerability Scoring System).

CVSS Score	Severity	Description
9.0 – 10.0	Critical	Exploitable, high impact, immediate remediation required.
7.0 – 8.9	High	Significant impact, remediate soon.
4.0 – 6.9	Medium	Moderate impact, remediate based on risk.
0.1 – 3.9	Low	Low impact, remediate when possible.

4. COMMON VULNERABILITY SOURCES



5. TOOLS USED

	Nessus (Vulnerability scanner)
	OpenVAS (Open source scanner)
	Qualys (Cloud-based scanning)
	Nmap (Network scanning)
	AWS Inspector (Cloud vulnerability assessment)
	Microsoft Defender for Cloud (Cloud security and scanning)

6. REMEDIATION METHODS

- Apply security patches
- Update configurations
- Disable or remove vulnerable services
- Remove unused software
- Apply access controls
- Upgrade to supported versions
- Implement compensating controls (e.g. WAF, network rules)

7. VERIFYING FIXES

- 1 Rescan using the same or a different tool.
- 2 Confirm the vulnerability no longer appears.
- 3 Verify the system is still functioning correctly.
- 4 Document the fix and update the status.
- 5 Monitor for reoccurrence.



8. KEY TAKEAWAYS

- ✓ Vulnerability management is a continuous process.
- ✓ Regular scanning helps find security weaknesses early.
- ✓ Severity and exposure determine remediation priority.
- ✓ Focus on the highest risk vulnerabilities first.
- ✓ Verify fixes to ensure the vulnerability is fully closed.
- ✓ Use a combination of tools and manual checks.
- ✓ It improves security, reduces risk, and supports compliance.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

ENDPOINT SECURITY EXPLAINED



How antivirus, Endpoint Detection and Response (EDR), and device hardening help protect computers and servers.

1. WHAT IS ENDPOINT SECURITY?

Endpoint security protects individual devices such as laptops, desktops, servers, and cloud instances from malware, attacks, and unauthorized access. It uses a combination of tools, policies, and monitoring to detect, prevent, and respond to threats.



It helps to:

- ✓ Prevent malware and unauthorized access
- ✓ Detect and respond to threats
- ✓ Protect sensitive data on devices
- ✓ Keep systems secure and compliant

2. KEY COMPONENTS



ANTIVIRUS (AV)

Detects and blocks known malware using signature and behavior-based detection.



EDR

Monitors endpoint activity, detects suspicious behavior, and helps with investigation and response.



DEVICE HARDENING

Secures the operating system and applications to reduce the attack surface.



POLICIES AND CONTROLS

Enforces security settings, access controls, and updates.



MONITORING AND ALERTING

Provides real-time visibility and alerts on suspicious activity.

3. HOW THEY WORK TOGETHER



1. PREVENT

Antivirus blocks known malware and malicious files.



2. DETECT

EDR identifies suspicious and malicious behavior in real time.



3. RESPOND

EDR provides tools to investigate, contain, and remove threats.



4. HARDEN

Device hardening reduces vulnerabilities and prevents common attacks.



5. CONTINUOUS PROTECTION

Ongoing monitoring, updates, and policy enforcement keep devices secure.

4. ANTIVIRUS VS EDR

Feature	Antivirus (AV)	Endpoint Detection and Response (EDR)
Main purpose	Detects and blocks known malware	Detects, investigates and responds to threats
Detection method	Signature-based and basic behavior	Behavior-based, analytics and threat intelligence
Visibility	Limited	Deep visibility into endpoint activity
Response capability	Blocks/removes malware	Isolates device, stops malicious activity, helps with investigation
Best for	Known and common threats	Advanced and unknown threats

5. EXAMPLES OF THREATS



Malware (viruses, worms, trojans, ransomware)



Fileless malware



Suspicious processes



Malicious scripts and macros



Unauthorized access attempts



Credential theft



Lateral movement to other systems



Data exfiltration

6. DEVICE HARDENING TIPS



Keep operating system and applications updated



Disable unnecessary services



Use strong passwords and multi-factor authentication



Configure host firewall



Apply endpoint security policies



Remove or disable unused software



Restrict administrative privileges



Enable disk encryption

7. COMMON ENDPOINT SECURITY TOOLS

Microsoft Defender	CrowdStrike	SentinelOne	Trellix	ESET
Sophos	Bitdefender	Palo Alto Cortex	VMware Carbon Black	Cisco Secure Endpoint

8. KEY TAKEAWAYS

- ✓ Endpoint security protects laptops, desktops, servers, and cloud instances.
- ✓ Antivirus blocks known malware, while EDR detects and responds to advanced threats.
- ✓ Device hardening reduces vulnerabilities and helps prevent attacks.
- ✓ Use a combination of tools, monitoring, and policies for better protection.
- ✓ Keep systems updated and remove unnecessary software and services.
- ✓ Endpoint security helps stop attacks early and reduces the impact of incidents.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

INCIDENT RESPONSE FUNDAMENTALS



Preparation, detection, analysis, containment, eradication, recovery, and lessons learned.

1. WHAT IS INCIDENT RESPONSE?

Incident response is a structured process to detect, analyze, contain, eradicate, and recover from security incidents, and learn from them to improve defenses and reduce the chance of future incidents.



It helps organizations:

- ✓ Respond quickly to security threats
- ✓ Reduce damage and downtime
- ✓ Restore normal operations
- ✓ Improve security defenses
- ✓ Meet legal and compliance requirements

2. INCIDENT RESPONSE LIFECYCLE

- 1 PREPARATION**
Build plans, tools, processes and a response team.
- 2 DETECTION**
Identify and validate potential security incidents.
- 3 ANALYSIS**
Investigate, determine scope, impact, and root cause.
- 4 CONTAINMENT**
Stop the attack and limit further damage.
- 5 ERADICATION**
Remove the threat and close the vulnerabilities.
- 6 RECOVERY**
Restore systems and normal operations.
- 7 LESSONS LEARNED**
Review the incident, identify gaps, and improve defenses.

3. EXAMPLE SCENARIO

- Detection**
Unusual login activity is detected on a server.
- Analysis**
Investigate the logs and confirm it is a compromised account.
- Containment**
Disable the account and block the attacker's IP.
- Eradication**
Remove malware and close the vulnerability.
- Recovery**
Restore normal services and monitor for recurrence.
- Lessons Learned**
Update policies, improve monitoring, and train the team.

4. KEY ACTIVITIES AT EACH STAGE

Stage	Key Activities
Preparation	- Create incident response plan - Define team roles and communication - Set up tools and environment
Detection	- Monitor logs, alerts and telemetry - Identify suspicious activity - Validate and classify the incident
Analysis	- Investigate evidence (logs, memory, network) - Determine scope and impact - Identify root cause
Containment	- Isolate affected systems - Block malicious traffic - Prevent further spread
Eradication	- Remove malware and backdoors - Patch vulnerabilities - Revoke compromised credentials
Recovery	- Restore systems and data - Verify systems are working correctly - Monitor for any remaining threats
Lessons Learned	- Document what happened - Identify gaps and improvements - Update policies and controls - Provide training to the team

5. COMMON INCIDENT TYPES

- Malware infection** (viruses, ransomware, trojans)
- Unauthorized access** (compromised accounts)
- Data breach or exfiltration**
- Phishing attacks**
- Web application attacks** (SQL injection, XSS)
- Cloud security incidents**
- Network intrusions**
- Insider threats**
- Denial of Service (DoS/DDoS)**
- Misconfiguration and exposed resources**

6. IMPORTANT TOOLS

- Splunk** (log analysis and monitoring)
- ELK Stack** (Elasticsearch, Logstash, Kibana)
- Microsoft Sentinel** (SIEM and threat detection)
- CrowdStrike** (EDR and endpoint security)
- Carbon Black** (endpoint protection)
- Wireshark** (network analysis)
- TheHive** (incident management)
- VirusTotal** (malware analysis)

7. INCIDENT RESPONSE BEST PRACTICES

- ✓ Have a documented incident response plan
- ✓ Practice with real scenarios and simulations
- ✓ Maintain good logging and monitoring
- ✓ Keep systems and software updated
- ✓ Use automation to speed up response
- ✓ Communicate clearly with stakeholders

8. KEY TAKEAWAYS

- ✓ Incident response is a structured process.
- ✓ Detect incidents early to reduce impact.
- ✓ Contain and eradicate threats quickly.
- ✓ Recover systems safely and verify they work.
- ✓ Learn from every incident to improve security.
- ✓ A well-prepared team responds faster and reduces future risk.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

INVESTIGATING A SUSPICIOUS LOGIN



Follow a beginner-friendly security investigation using login records, IP addresses, timestamps, and supporting evidence.

1. SCENARIO

A user reports unusual activity on their account. You need to investigate a suspicious login using system logs, IP address information, timestamps and supporting evidence.



Key questions to answer:

- ✓ Was the login successful?
- ✓ Where did the login come from?
- ✓ Was it the user or an attacker?
- ✓ What actions happened after the login?
- ✓ Do we have enough evidence?

2. INVESTIGATION STEPS

- 1 FIND THE LOGIN RECORDS**
Search system or authentication logs for the exact time and user.
- 2 CHECK THE DETAILS**
Review timestamp, IP address, location, device and login method (e.g. password, key, MFA).
- 3 ANALYZE THE IP ADDRESS**
Check if the IP is known, trusted or suspicious using IP lookup tools.
- 4 LOOK FOR RELATED ACTIVITY**
Check what the user did after logging in (commands, file access, privilege changes, etc.).
- 5 DETERMINE IF IT IS SUSPICIOUS**
Compare with normal user behavior and organization's policies.
- 6 TAKE ACTION**
If malicious, contain the account, preserve evidence and escalate according to your process.

3. USEFUL LOG SOURCES



Linux Authentication Logs
/var/log/auth.log
/var/log/secure



Windows Security Logs
Event Viewer
(Security Event ID 4624, 4625)



Cloud Logs (AWS, Azure, GCP)
CloudTrail (AWS)
Sign-in logs (Azure)
Audit logs (GCP)



Application Logs
Web server logs, VPN logs,
database logs, etc.



Network Logs
Firewall logs, VPN logs,
IDS/IPS logs, proxy logs

4. CHECKING IP ADDRESS INFO



IP Geolocation
ipinfo.io, whois, geoiplookup



Reputation Check
VirusTotal, AbuseIPDB, Talos



Compare with Normal Activity
Is this IP/location usual for the user?



Look for Risk Indicators
VPN, proxy, TOR, malicious reputation

5. EXAMPLE: INVESTIGATE A LINUX LOGIN

```
ubuntu@server:~$ sudo tail -n 5 /var/log/auth.log
Oct 10 14:22:01 server1 sshd[1234]: Failed password
Oct 10 14:22:15 server1 sshd[1234]: Failed password
Oct 10 14:22:40 server1 sshd[1234]: Accepted password
for user admin from 203.0.113.25 port 54322 ssh2
```

Timestamp
when the login
occurred

Accepted login
for user admin

Source
IP address

Port and
login method

6. EXAMPLE: INVESTIGATE A WINDOWS LOGIN

```
Log Name: Security
Source: Microsoft-Windows-Security-Auditing
Event ID: 4624
Level: Information
Date: 10/10/2026 14:22:40
Account Name: admin
Logon Type: 3 (Network)
Source Network Address: 203.0.113.25
Source Port: 54322
Logon Process: NtLmSsp
```

Successful login
event (4624)

Timestamp
of the login

Source IP address

Logon type
(3 = network)

7. ANALYZE AND VERIFY

- 🔍 Check if the IP address is from a known location.
- 🌐 Verify if the IP is malicious or high risk.
- 📋 Look for multiple failed attempts before success.
- ⚙️ Check what the user did after logging in.
- 🔄 Compare with normal user behavior.
- ✅ Confirm if the evidence indicates a real threat or false positive.

8. ACTIONS IF SUSPICIOUS



Reset the user's password.



Revoke active sessions.



Block the IP address.



Enable or enforce MFA.



Collect and preserve evidence.



Escalate to the security team.

9. KEY TAKEAWAYS

- ✓ Login logs provide valuable evidence.
- ✓ Always check timestamps, IP addresses, and user behavior.
- ✓ Use multiple data sources for a complete investigation.
- ✓ Compare with normal activity to avoid false positives.
- ✓ Follow your organization's incident response process.
- ✓ Document your findings and actions.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

YOUR FIRST DEFENSIVE SECURITY LAB



Perform a safe, guided investigation using sample logs, identify suspicious activity, document findings, and recommend defensive actions.

1. LAB OVERVIEW

In this lab, you will act as a security analyst and investigate real-looking sample logs. You will identify suspicious activity, analyze the findings, document your results, and recommend defensive actions.



What you will practice:

- ✓ Investigating authentication logs
- ✓ Finding suspicious activity
- ✓ Analyzing IP addresses and behavior
- ✓ Documenting your investigation
- ✓ Recommending defensive actions

2. LAB SCENARIO

Your organization has detected multiple failed login attempts followed by a successful login from an unusual location. Investigate the logs below and determine if this is malicious.

Oct 10 08:12:14 server sshd[2314]:
Failed password for invalid user
root from 185.199.110.23 port 51022
ssh2

Oct 10 08:13:02 server sshd[2314]:
Failed password for user admin
from 185.199.110.23 port 51024
ssh2

Oct 10 08:14:37 server sshd[2314]:
Accepted password for user admin
from 185.199.110.23 port 51026
ssh2

3. INVESTIGATION STEPS

- 1 EXPLORE THE LOGS**
Review the provided log files and understand the events.
- 2 IDENTIFY SUSPICIOUS ACTIVITY**
Look for failed logins, unusual IP addresses, and successful logins after failures.
- 3 ANALYZE THE EVIDENCE**
Check IP reputation, geolocation, timestamps, and user behavior.
- 4 DOCUMENT YOUR FINDINGS**
Summarize what happened, include key evidence, and explain your conclusion.
- 5 RECOMMEND DEFENSIVE ACTIONS**
Suggest steps to prevent or detect similar activity in the future.

4. USEFUL COMMANDS

Task	Command
View auth logs (Linux)	<code>sudo tail -n 50 /var/log/auth.log</code>
Filter failed logins	<code>grep "Failed password" /var/log/auth.log</code>
Filter successful logins	<code>grep "Accepted password" /var/log/auth.log</code>
Show unique IP addresses	<code>grep "Failed password" /var/log/auth.log awk '{print \$(NF-3)}' sort uniq</code>
Check IP geolocation (Linux - ipinfo.io)	<code>curl ipinfo.io/185.199.110.23</code>
Check IP reputation (AbuseIPDB)	<code>curl https://api.abuseipdb.com/api/v2/check?ipAddress=185.199.110.23</code>
Check failed login count	<code>grep "Failed password" /var/log/auth.log wc -l</code>

5. SAMPLE INVESTIGATION OUTPUT

Suspicious IP: 185.199.110.23
Geolocation: Frankfurt, Germany
Reputation: High risk (reported for brute force activity)
Activity:
 • 5 failed login attempts (08:12 - 08:13)
 • 1 successful login (08:14)
User: admin
Conclusion:
 Likely a brute force attack that resulted in a successful login.

6. DEFENSIVE ACTIONS

- Block the IP address on firewall.
- Enforce multi-factor authentication (MFA).
- Review and strengthen password policy.
- Monitor for similar activity across all systems.
- Investigate user activity after the login.
- Set up alerts for multiple failed login attempts.

7. DOCUMENTATION TEMPLATE

1. Summary of the incident
2. Timeline of events (with timestamps)
3. Key findings (IP address, user, system, evidence)
4. Analysis (why it is suspicious)
5. Conclusion (malicious or not)
6. Recommended actions
7. Additional notes (lessons learned)



8. KEY TAKEAWAYS

- ✓ System logs are valuable for detecting suspicious activity.
- ✓ Look for patterns such as multiple failed logins and unusual locations.
- ✓ Verify IP addresses using reputation and geolocation tools.
- ✓ Document your investigation clearly with evidence.
- ✓ Recommend practical defensive actions to reduce risk.
- ✓ This lab builds the core skills of a SOC analyst.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta